

Fecha: 26 de Septiembre del 2026

CNO 4: CIBERSEGURIDAD

ACTIVIDAD 11 LAB: VALIDATION OF START OF PATH

Documentación

Maestro: Servando López Contreras

Alumno: Quetzal Olin Rodríguez Jiménez

Contenido

OBJETIVO.....	2
AMBEINTE DE LABORATORIO	3
ANÁLISIS DE LA VULNERABILIDAD Y FORMA DE RESOLUCIÓN.....	5
COMANDOS UTILIZADOS	5
RESULTADOS	6
CONCLUSIONES	6

OBJETIVO

Exploitar una validación débil que comprueba solo el inicio de la ruta (start-of-path) para leer archivos fuera del directorio permitido (por ejemplo /etc/passwd). El servidor valida que la ruta comience con un prefijo permitido, pero la comprobación es insuficiente y puede ser burlada con payloads que cambian la interpretación de la ruta tras la normalización o decodificación.

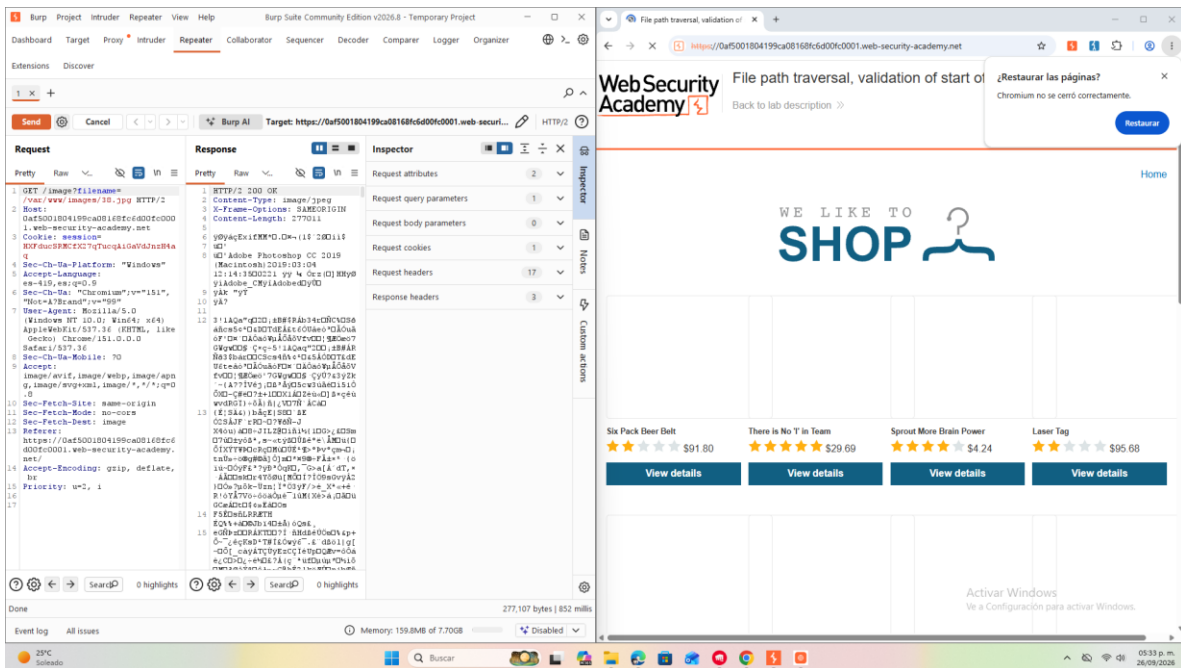
AMBIENTE DE LABORATORIO

Captura la petición objetivo

Localiza la petición GET que incluye filename= (o parámetro equivalente).

Confirmar la validación de inicio

Prueba con un valor legítimo (p. ej. filename=/images/product.png) para ver comportamiento normal.



Prueba de bypass por segmentación y normalización

Ejemplo: filename=/images/..%2f..%2fetc/passwd (mezcla de segmentos y codificación).

filename=/images/../../../../ o filename=/images/../../../../../../../../

The screenshot shows Burp Suite on the left and a web browser on the right. In Burp Suite, the 'Request' tab displays an HTTP GET request to `/image?filename=/var/www/images/../../../../etc/passwd`. The 'Response' tab shows a 400 Bad Request status. The browser on the right shows the WebSecurity Academy 'SHOP' page. A notification at the top right says 'File path traversal, validation of start of path' and 'Restaurar las páginas?'. The browser's address bar shows the URL `https://0af5001804199ca08168fc6d00c0001.web-security-academy.net`.

Bypass con inserción de prefijo válido + traversal

filename=/images/../../../../etc/passwd (si el filtro elimina ../ no recursivamente, la concatenación puede producir ../../etc/passwd)

filename=/images/../../../../etc/passwd o
filename=/images/../../../../../../../../../../../../etc/passwd

The screenshot shows Burp Suite on the left and a web browser on the right. In Burp Suite, the 'Request' tab displays an HTTP GET request to `/image?filename=/var/www/images/../../../../../../../../../../../../etc/passwd`. The 'Response' tab shows a 200 OK status. The browser on the right shows the WebSecurity Academy 'SHOP' page. A notification at the top right says 'File path traversal, validation of start of path' and 'LAB Not solved'. The browser's address bar shows the URL `https://0af5001804199ca08168fc6d00c0001.web-security-academy.net`.

Obtuvimos acceso

ANÁLISIS DE LA VULNERABILIDAD Y FORMA DE RESOLUCIÓN

Validación basada en prefijo literal: funciones como `startsWith("/images/")` son insuficientes si se aplican sobre la entrada sin normalizar.

Decodificación en etapas: si el servidor decodifica percent-encodings en distintos puntos del pipeline, una entrada doblemente codificada puede evadir la comprobación inicial y transformarse en una ruta de traversal tras una decodificación posterior.

Sanitización no recursiva: reemplazos simples (`replace("../", "")`) o limpiezas de una sola pasada permiten técnicas de anidación (por ejemplo `../../../../`) que se recomponen en `../` después del filtrado.

COMANDOS UTILIZADOS

Burp Suite – Proxy (Intercept ON): Se activó la opción *Intercept on* para capturar las peticiones HTTP generadas por el navegador.

Forward: Se utilizó el botón *Forward* para permitir que la página cargara después de interceptar las solicitudes.

Observación de tráfico GET: Se identificaron múltiples peticiones de tipo **GET** hacia recursos estáticos.

Prueba de acceso a directorios: Se intentó navegar hacia el directorio raíz regresando niveles (`../`) para comprobar la estructura de directorios y posibles accesos indebidos.

Send to Repeater: Envío de la solicitud del parámetro filename al entorno de pruebas repetitivas de Burp Suite.

Manipulación de Parámetro GET (filename): Modificación del valor por secuencias anidadas no recursivas (....//) para evadir los filtros de validación de entradas.

RESULTADOS

Confirmación de la vulnerabilidad: La validación que comprueba solo el **inicio de la ruta** (start-of-path) sin canonicalizar la ruta completa es insuficiente; se pudo construir una ruta que **literalmente** comienza con el prefijo permitido pero que, tras decodificación/normalización, apunta fuera del directorio autorizado.

Payloads efectivos: Se verificaron payloads que combinan **prefijo válido + traversal** (por ejemplo /images/....//....//etc/passwd), variantes con **percent-encoding** simple (/images/%2e%2e/%2e%2e/etc/passwd) y **doble codificación** (/images/%252e%252e%252f%252e%252e%252fetc%252fpasswd) que, según la lógica de decodificación del servidor, permiten acceder a /etc/passwd.

Comportamiento del servidor: El servidor realiza comprobaciones sobre la cadena original (startsWith) y/o decodificaciones en etapas; la falta de normalización previa a la validación permite que la ruta final escape del directorio base.

CONCLUSIONES

Confidencialidad: Exposición de archivos sensibles del sistema (por ejemplo /etc/passwd) y potencial acceso a otros ficheros internos si existen rutas relativas a datos sensibles.

Escalada de riesgo: Dependiendo de permisos y archivos accesibles, el fallo puede facilitar enumeración de usuarios, información del sistema o servir como vector para ataques posteriores (p. ej. lectura de archivos de configuración con credenciales).

Alcance: Afecta a cualquier endpoint que valide solo el prefijo de la ruta sin normalizarla y que permita al usuario controlar segmentos de la ruta.

